

Processing Personal Data under the EU AI Act: Interaction and Conflict with the GDPR

Marlon Müller¹

¹Technical University of Munich, Germany

Introduction

The training of Artificial Intelligence (AI) systems relies heavily on the processing of large amounts of data. In practice a large share of this data is personal data. This overlap between AI and personal data processing brings two major regulatory instruments of the European Union (EU) into contact: the General Data Protection Regulation (GDPR) and the Artificial Intelligence Act (AIA).

Both regulatory frameworks have the same goal of protecting fundamental rights and freedoms of individuals, and they both apply simultaneously to providers of high-risk AI systems that process personal data. This relationship is conceptualized as an additive one in Art. 2(7) AIA [1]. They also follow a different regulatory logic, with the GDPR protecting the fundamental right of privacy and the AIA acting as a product safety regulation for AI systems.

This paper analyzes how this co-regulation affects providers and argues that the relationship is more complex than the AIA's additive model suggests. For this purpose, the paper first establishes a role mapping and will then examine the parallel obligations that arise from the two frameworks. Finally, it will show that the debiasing exception in Art. 10(5) AIA creates a conflict, that neither framework can resolve on its own.

Two Frameworks, One Actor

In both regulations there are distinct roles that entities can take on and that have different legal obligations. The GDPR distinguishes between data controllers and data processors, while the AIA distinguishes between providers and deployers of AI systems. In practice the roles of the two frameworks do not map onto each other statically, even though they often overlap if personal data that falls under the GDPR is involved.

During the development and training of an AI system the provider can usually be considered to be the data controller, as it determines the purposes and means of the processing of personal data. Even

though the provider can still give instructions to the deployer during the deployment phase on how to use the system and how to handle personal data, these constraints are merely technical and are not sufficient to make the provider a data processor during deployment. This role will be taken on by the deployer instead, as he keeps control over the purposes of the processing of personal data and, most crucially, can control who is a data subject, usually customers of the deployer, of that processing. If the inference does not run on the deployer's infrastructure and personal data flows to the server the AI system is hosted on, the natural or legal person that operates that server, which is either the provider, importer or distributor of the AI system, can be considered a data processor during inference. If the system is self-hosted by the deployer, the provider exits the processing chain entirely and is not subject to GDPR after deployment. [1, 2]

While the mapping of these roles is grounded in the legal definitions of the two frameworks and the practical realities of AI development and deployment, there may nevertheless be edge cases or legal and contractual constellations in which this mapping does not hold.

One important gap of the overlap of these roles can be found whenever the provider of a continuous learning system feeds inference data back into retraining. In this case, the provider may transition from processor to controller for that secondary processing, as it determines a new purpose for its own benefit. This practice could conflict with GDPR Articles 5(1)(b) and 6 [2], but the AIA addresses it only obliquely through Article 15 on feedback loops, without addressing or resolving the GDPR consequences [1].

Parallel Obligations

In Article 2(7) the AIA states that the obligations of the GDPR apply in addition to the obligations of the AIA. This means that providers and deployers of high-risk AI systems that process personal data are subject to both sets of obligations simultaneously.

This creates a complex regulatory landscape for these entities, as they must navigate and comply with the requirements of both frameworks. The GDPR has very specific obligations regarding data protection, such as data minimization, purpose limitation, and the rights of data subjects, while the AIA has its own set of obligations related to the safety and transparency of AI systems.

In the following, the paper will analyze some of the most important obligations that arise from this co-regulation and whether they are complementary or conflicting.

Transparency Obligations

Both the GDPR and the AIA have certain transparency obligations, but they differ significantly in their purpose and scope. The GDPR defines its transparency obligations for data controllers in Articles 13 and 14. Main purpose of these obligations is to inform the data subjects about the processing of their personal data, including the purposes of the processing, the categories of data being processed as well as the recipients and time of storage of the data. It is notable that the GDPR does not require data controllers to disclose any information about the inner workings of the processing itself, such as the algorithms used or the logic behind the processing. [2]

The AIA, on the other hand, has transparency obligations that are focused on the interpretability and explainability of the AI system itself. These obligations are outlined in Article 13(1) and Article 13(3)(f) and requires providers to provide instructions for use with their system. However, these instructions for use are to be provided to the deployer and not to the data subjects, and they are not required to include any information about the processing of personal data specifically. The only transparency requirement, directly targeting natural persons, and therefore potentially data subjects, is the disclosure of the fact that they are interacting with an AI system, as defined in Article 50 AIA. [1]

While both frameworks have transparency obligations, they are not necessarily complementary, as they target different audiences and have different purposes. As they also don't cause any direct conflicts, these obligations can be seen as parallel and independent of each other.

Data Governance

The governance of data is a crucial aspect of the AIA, especially to ensure the quality and representativeness of the data used for training and testing AI system. Apart from data quality Article 10(2)(b) AIA also demands that providers consider the ori-

gin of the data as well as the original purpose of the collection of personal data [1]. Even though this clause references the original purpose of the collection, it does not explicitly mandates the compliance with the purpose limitation principle established in Article 5(1)(b) GDPR. Not only does the AIA fail to explicitly require compliance with the GDPR's purpose limitation principle, it requires providers to ensure a representative and bias free dataset, which, in practice, requires large datasets [3] as well as the collection of additional data that may not be necessary for the original purpose of the collection, and therefore conflicts with the GDPR's principle of data minimization in Article 5(1)(c) [2].

Right to be Forgotten

The right to be forgotten is established in Article 17 GDPR and allows data subjects to request the deletion of their personal data under certain conditions. This right is regularly confirmed and strengthened by the Court of Justice of the European Union (CJEU) and other national courts [4, 5]. Personal data that is used for training an AI system becomes an integral part of the AI model and is not stored in a traditional sense, but rather encoded in the parameters of the model and the influence of a single data point on the model is not easily identifiable. In cases where it is possible to extract the training data from the model in a way that could allow the identification of a data subject the European Data Protection Board (EDPB) has clarified that the right to be forgotten applies to the trained model as well [6]. In practice this requires the AI model to unlearn this data point, which is technically possible but may not always be feasible [7, 8]. Even though the right to be forgotten is a fundamental right under the GDPR and compliance with it is a legal obligation for data controllers, the AIA does not explicitly ensure that providers of AI systems have the technical means to unlearn data points from their model or any other way to comply with the right to be forgotten. This leaves a gap between a significant obligation under the GDPR and the requirements of the AIA.

In general these obligations show that the co-regulation of the GDPR and the AIA are additive in some cases, but they also have significant regulatory gaps and structural tensions between the compliance with both frameworks.

The Debiasing Exception

Conclusion

References

- [1] European Parliament and Council of the European Union. "Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 laying down harmonised rules on artificial intelligence and amending Regulations (EC) No 300/2008, (EU) No 167/2013, (EU) No 168/2013, (EU) 2018/858, (EU) 2018/1139 and (EU) 2019/2144 and Directives 2014/90/EU, (EU) 2016/797 and (EU) 2020/1828 (Artificial Intelligence Act)". In: *Official Journal of the European Union* L 305 (2024). CELEX number: 32024R1689, pp. 1–73. URL: <http://europa.eu>.
- [2] European Parliament and Council of the European Union. "Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data (General Data Protection Regulation)". In: *Official Journal of the European Union* L 129.L 129 (2016).
- [3] D. Samuel and Gal Chechik. "Distributional Robustness Loss for Long-tail Learning". In: *2021 IEEE/CVF International Conference on Computer Vision (ICCV)* (2021), pp. 9475–9484. DOI: 10.1109/iccv48922.2021.00936.
- [4] Court of Justice of the European Union. *Google Spain SL and Google Inc. v Agencia Española de Protección de Datos (AEPD) and Mario Costeja González*. Case C-131/12, ECLI:EU:C:2014:317. Judgment of the Court (Grand Chamber), 13 May 2014. May 2014. URL: <https://eur-lex.europa.eu/legal-content/EN/CASE/?uri=celex:62012CJ0131>.
- [5] Robert Kazemi. § 6 Rechte des Betroffenen / D. Recht auf Löschung/"Recht auf Vergessenwerden", Art. 17 DSGVO. de. Jan. 2018. URL: <https://www.haufe.de/id/beitrag/6-rechte-des-betroffenen-d-recht-auf-loeschungsrecht-auf-vergessenwerden-art17-dsgvo-HI11400626.html>.
- [6] European Data Protection Board. *Opinion 28/2024 on certain data protection aspects related to the processing of personal data in the context of AI models*. <https://edpb.europa.eu>. Dec. 2024.
- [7] Federica Velli. "Processing Personal Data in the Context of AI Models: EDPB's Opinion 28/2024". In: *DOAJ (DOAJ: Directory Of Open Access Journals)* (Feb. 2025). DOI: 10.15166/2499-8249/822. URL: <https://doaj.org/article/82a9cdb0f5244e98bf5016e743bfafc7>.
- [8] Bjørn Aslak Juliussen, Jon Petter Rui, and Dag Johansen. "Algorithms that forget: Machine unlearning and the right to erasure". In: *Computer Law & Security Review* 51 (Sept. 2023), p. 105885. DOI: 10.1016/j.clsr.2023.105885. URL: <https://doi.org/10.1016/j.clsr.2023.105885>.